

Topic - I : Footprinting Tools - Conducting Competitive Intelligence

Footprinting is the process of gathering information about a target organization. In passive footprinting information is collected from public sources without directly scanning or attacking the company's servers.

For Ex: ABC Technologies, the following tools can be used:

1) Domain Registration Details - WHOIS

WHOIS provides information about the company's registration domain.

It can reveal:

- Domain register
- Name Servers
- Registration & expiry data
- Domain Status
- Organization details, if publicly available

Competitive Intelligence : Helps understand the company's domain infrastructure, DNS Provider, Domain History.

Ex: WHOIS abc technologies . com

2) Employee Email Addresses - The Harvester

- The Harvester is an OSINT tool used to collect publicly available information from supported search and public data sources.

It can identify :

- Publicly employee email addresses
- Employee names
- Email naming patterns
- Public hosts & subdomains

Competitive Intelligence : Helps understand the company public employee / contact structure & identify information that could be exposed to phishing risks.

Ex: The Harvester - d abctechnologies.com - b bing

3) Technology Stack - Builtwith / wappalizer

Builtwith and wappalizer identify technologies associated with websites.

They may identify :

- web servers - Apache / Nginx
- CMS - wordpress
- Framework - React / Angular
- CDN - cloud flare
- Analytics services

Competitive Intelligence : Helps compare the technologies used by ABC Technologies with competitors and identify potentially outdated technologies.

4) Public Subdomains - crt.sh

Crt.sh searches public Certificate transparency records to find hostnames associated with a domain.

Public Subdomains :

www.abc technologies.com

mail.abc technologies.com

api.abc technologies.com

portal.abc technologies.com

Competitive Intelligence :- Helps understand the company's public facing infrastructure & identify services such as API's, Portals, mail systems & development environments.

Topic 2 : DNS Zone Transfer Authorized Penetration Testing

A DNS zone transfer is a process where DNS records are copied from one DNS server to another. If a DNS server is misconfigured, an unauthorized user may be able to retrieve the complete DNS zone information.

4) Use in Reconnaissance:

The retrieved information helps the authorized tester identify.

- Internal / related hosts: Host name & IP address can reveal network ^{Structure} x
- Mail servers: MX records identify system responsible for email.
- Subdomains: Names such as dev.example.com, & Port.example.com
- DNS Infrastructure: NS records identify authorize Domain NS Server

Conclusion:

During an authorized Penetration test, dig AXFR can be used to check whether a DNS server incorrectly Permits Zone transfer can reveal hosts, IP addresses, mail services a detailed view of targets DNS infra Infrastructure.

Topic - 3 Social Engineering Attacks & Counter measures

Social Engineering is an attack technique where attacks manipulate People into revealing confidential information such as username, passwords, OTP's. In this scenario, employees receive a fake email pretending to be from the IT dept and asking them to verify their login Credentials.

1) Type of Attack - Phishing

This is a phishing attack

Phishing occurs when an attacker sends a fraudulent

1) Find the DNS Name Server :

Use Nslookup or dig to identify the target authorize name servers.

Ex : nslookup -type = ns example.com (or)

dig ns example.com

Result : ns1.example.com
ns2.example.com.

2) Test the Zone Transfer

Use the dig command with AXFR. dig AXFR example.com

@ ns1.example.com here :

→ AXFR : Requests a complete DNS Zone transfer

→ example.com : Target domain

→ @ns1.example.com : DNS server being tested.

If the server is properly configured, the request should be refused.

If it is misconfigured, DNS records may be returned.

3) Information Obtained

A successful transfer can expose records such as

Record

A / AAAA

MX

NS

Information

Hostnames & their IP addresses

Mail services

DNS / name servers

emails or message that appears to come from a trusted source & tries to make victim reveal information.

Impersonation: Pretends to be IT department

Urgency: Uses an urgent security update to pressure employees into acting quickly.

2) Counter measures Employees should follow

A) Do not click the link immediately

Employees should avoid clicking links in unexpected suspicious ^{mails}

Benefit: Prevents users from being redirected to fake login.

B) Verify the sender:

check complete sender details

Benefit: Prevents from redirecting to a fake login

C) Verify with IT department

contact the IT dept using official phone or help desk

Benefit: Confirms the security update is genuine

D) Check the link carefully.

Employees should be careful about misspelled or unrelated ^{domains}

4) Security Awareness

Organization should regularly train employees to recognize → Fake login Pages, suspicious links.

→ Sender Impersonation

→ Urgent request for credentials.